

Detecting and Preventing Intrusions

BCS2420

Dr. Ashish Sai

ashish.sai@maastrichtuniversity.nl

Intrusion detection, network monitoring, vulnerability assessment, and various network-based attacks.

Intrusion Detection

- **Firewalls** provide **coarse perimeter shields**.
- **Intrusion Detection Systems (IDS)**, whether **host-based** or **network-based**, monitor and analyze for malicious activity that gets through.

- Human resources are needed to manage and explore **alarms**.
- Early research in IDS was driven by a need to **automate analysis of audit trails**.

Basic Terms

- An **intrusion** or **incident** **violates** security policy, or is an **imminent** threat.
- **Intrusion detection** monitors and analyzes system events to identify and report such intrusions.

An Intrusion Detection System (IDS)
automates this process by monitoring
events, logging data, analysis and means
to report.

Detection vs. Prevention

- An IDS detects **intrusions**, either in progress or after the fact, and collects evidence.
- An Intrusion Prevention System (IPS) includes **active responses** such as stopping **violations** or **altering network configurations**.
 - A IPS may operate passively as an IDS.
 - A true IPS requires automated real time responses.

Architectural Types

Type of IDS	Source of Events	Features
Network-based IDSs (NIDS)	Network packets	Collected at strategic points like network gateways.
Host-based IDSs (HIDS)	Kernel operations, logs, file systems	Focuses on a single host; pooling is needed for a network-wide perspective.

Event Outcomes

- IDS may **raise alarms** for processed events, which may or may not be intrusions.
- **Key goals:** minimize *false positives* (improves usability) and *false negatives* (prevents security failures).

Classification Perspective

- Intrusion detection involves classifying events as either **intruder behavior** or **legitimate user behavior**.
- There is a tradeoff between **false positives** and **negatives**.

Error Rates

Metric	Definition
False Positive Rate (FPR)	Ratio of false alarms to events with no intrusions.
False Negative Rate (FNR)	Ratio of missed intrusions to total actual intrusions.
True Positive Rate (TPR)	Detection rate: correctly identified intrusions out of total intrusions.
Alarm Precision (AP)	Ratio of correctly raised alarms to total alarms.

	intrusion	no intrusion
alarm raised	True Positive (TP) intrusion detected	False Positive (FP) false alarm
no alarm raised	False Negative (FN) intrusion missed	True Negative (TN) normal operation

False positive rate	$FPR = \frac{FP}{(FP+TN)}$
True negative rate	$TNR = 1 - FPR$
False negative rate	$FNR = 1 - TPR$
True positive rate	$TPR = \frac{TP}{(TP+FN)}$
Alarm precision	$AP = \frac{TP}{(TP+FP)}$

Example: Base Rates

- The **base rate** of incidence (intrusions) strongly affects the **accuracy of a detector**.
- Even with a low *false positive rate*, low *base rates* may lead to large numbers of *false alarms*.
- A useful IDS will both detect **intrusions** and provide **good alarm precision**.

Intrusion Detection

Methodological Approaches

- IDSs combine methods spanning different approaches.
- Three philosophical approaches: **signature-based, specification-based, and anomaly-based.**

IDS

Approach	Alarm When...	Pros, Cons, Notes
Signature-based	Events match known-bad patterns	Signatures built from known attacks; fast, accurate (fewer false positives); detects only already-known attacks
Specification-based	Events deviate from per-application specifications of legitimate actions	Manually developed spec of allowed; can detect new attacks; no alarm on newly seen allowed event; specs are protocol or program-specific
Anomaly-based	Events deviate from profiles of normal	Need training period to build profiles; can detect new attacks; false alarms (abnormal may be benign); accuracy depends on features profiled

Signature-Based Approach

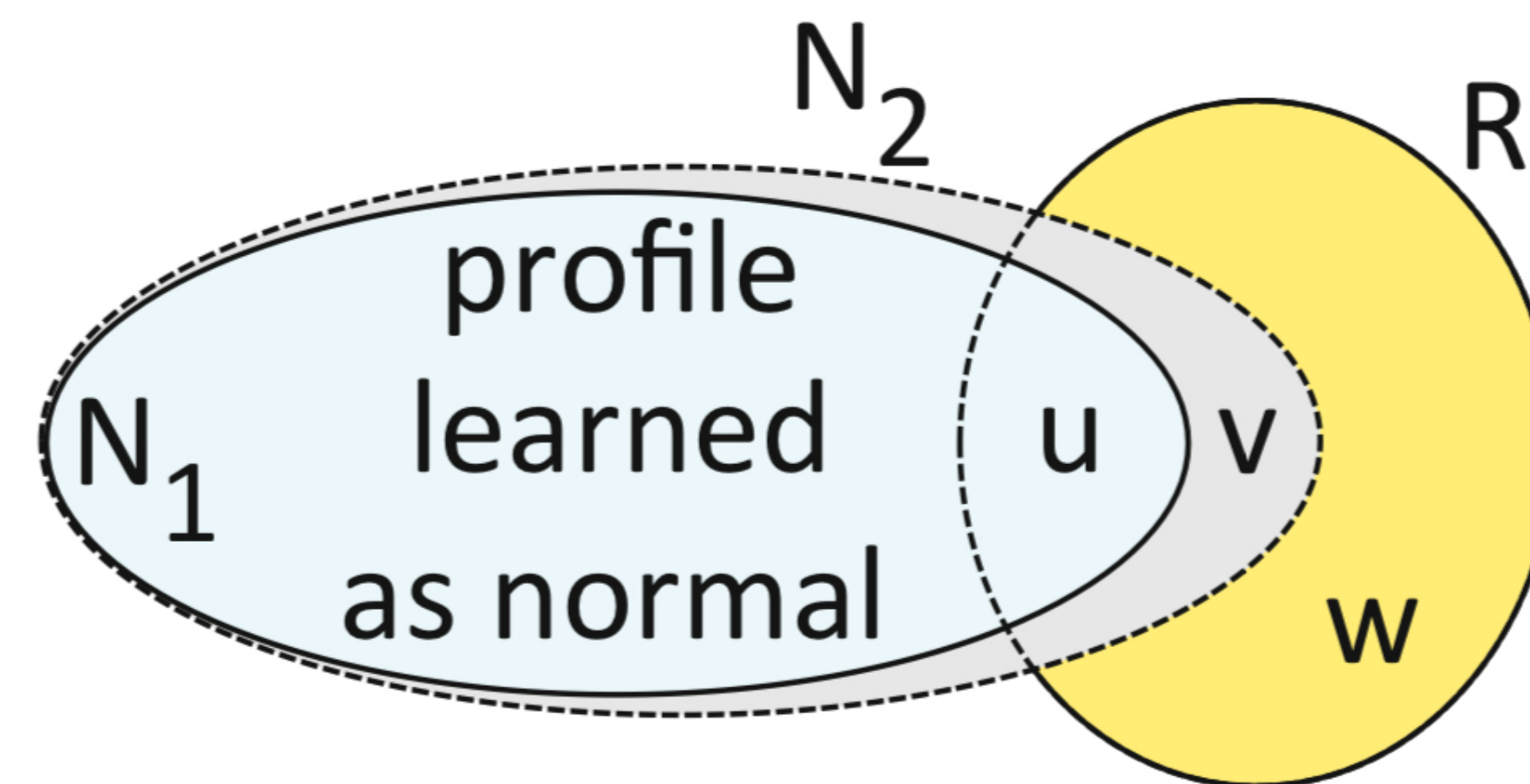
- Detects attacks by matching events to predefined signatures (like **anti-virus** or **packet filters**).
- **Pros:** Fast and accurate.
- **Cons:** Requires continuous updates and is limited to known attacks.
- Behavior-based signatures focus on **attack side effects**, not specific implementations.

a)

S
specified as allowed

Outer box is all possible behaviour

b)



FP

Oval R denotes intruder behaviour

Specification-Based Approach

- Defines allowed behaviors for applications or protocols, **raising alarms** for deviations.
- **Pros:** Detects new attacks with **zero false positives**.
- **Cons:** Time-intensive to develop and requires protocol-specific specifications.

Anomaly-Based Approach

- Creates profiles of normal activity during **training** and **detects deviations**.
- **Pros:** Capable of identifying **new attacks**.
- **Cons:** Prone to high **false positives**, difficult feature selection, reliance on intruder-free training, and session creep.

Challenges for Anomaly-Based Approach

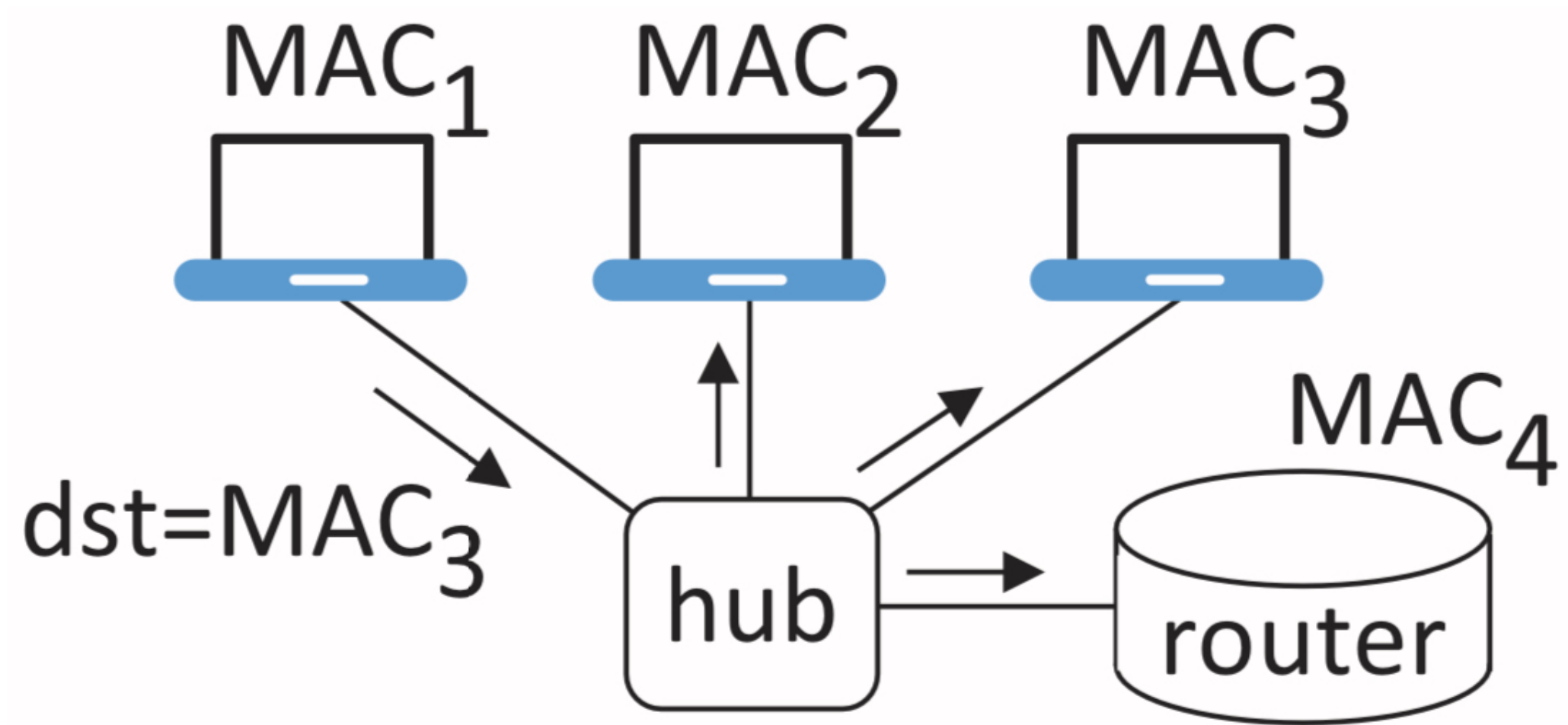
- **Feature Selection:** Difficult to select **effective features** for profiles.
- **Intruder-free training:** Must ensure **no malicious activity** during training.
- **Session creep:** Profiles should not adapt to **malicious activity** over time.

Sniffers, Reconnaissance Scanners, Vulnerability Scanners

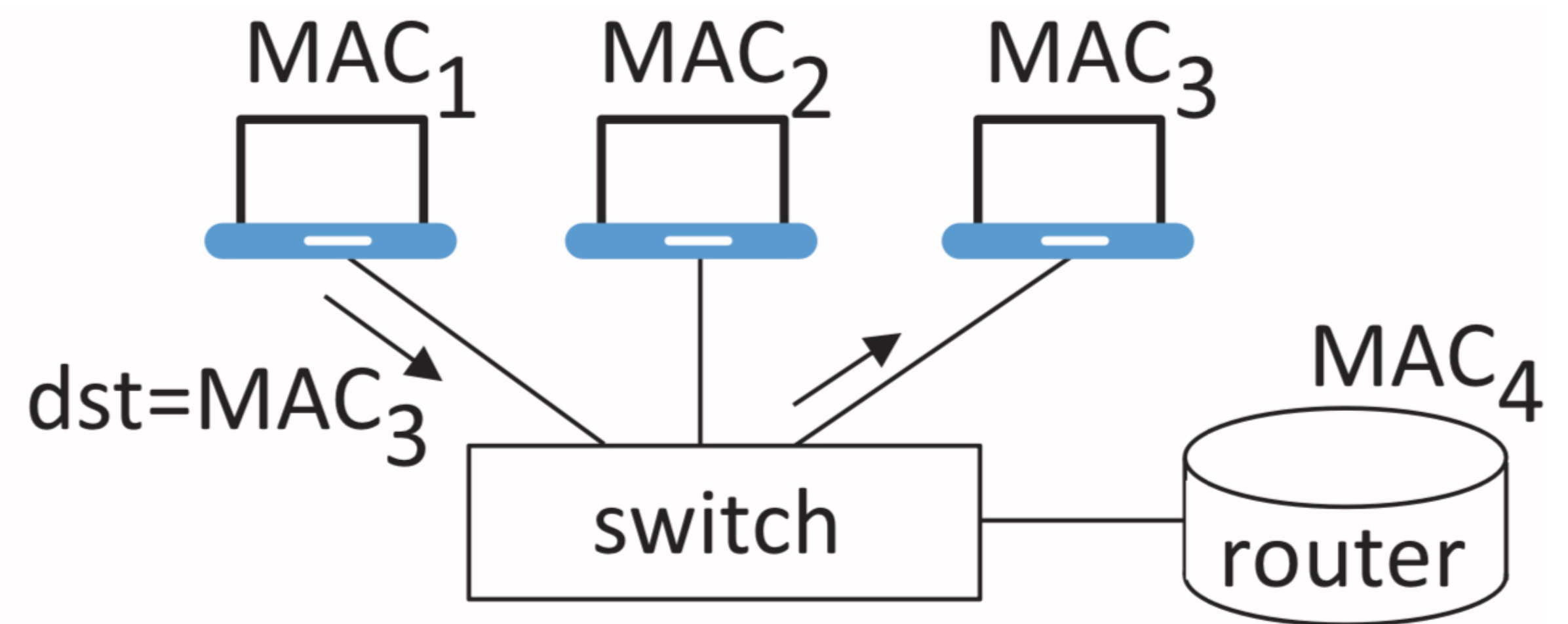
- A collection of tools with both **white-hat** and **black-hat** uses.
- **Packet sniffing**: for **NIDS**, tools to capture and retrieve packets at line-speed.
- Also of interest for *network monitoring* and *forensic analysis*.

Hubs and Switches

- **Hubs** broadcast all packets over all interfaces.
 - A NIC in **promiscuous mode** can **passively** collect all packets.
- **Switches** send packets only to the target host's interface.
 - A NIC in promiscuous mode will **not get all packets**, but can be compromised by **ARP spoofing**.



b)



Monitoring Support

- **SPAN port** (switched port analyzer) or port mirror **duplicates traffic** from other ports.
- **Taps** (test access ports) are dedicated devices facilitating **passive monitoring** (inline).

Vulnerability Assessment Tools

- Specialized intrusion detection tools **identifying weaknesses.**
- **Categories:** Known-vulnerable services, configuration errors, and weak default settings.
- **Purpose:** Highlight network vulnerabilities through reports and self-evaluation.
- **Examples:** Reconnaissance tools, vulnerability scanners, and penetration testing tools.

Limitations

- Vulnerability assessments are **limited to current exploits** and provide status at a fixed point in time.
- Dual use of tools creates uneasiness and ethical concerns.

A responsible disclosure approach is recommended.

Port Scanning

- Identifies **open ports** by sending probes.
- A port can be **open, closed, or blocked.**
- Detects **port scanning** to coordinate with **perimeter defenses** to block.
- Identifies services offered on **target hosts** and their OS for **vulnerability exploits.**

OS Fingerprinting

- **Passive** or **active** methods that identify a remote machine's OS and its version.
- **Active methods** send *TCP* connections or *ICMP* requests with non-standard headers.
- **Passive methods** inspect both *TCP* headers and application-level *HTTP* messages.

Example of `Nmap` a dual-use network scanner.

Vulnerability Scanner Example

- **Nessus** is a widely used remote vulnerability scanner, with vast libraries of plugins for *specific vulnerabilities*.
- Can specify scan **targets**, **port ranges**, **types of ports**, and which plugins to run.

Packet Capture Utilities

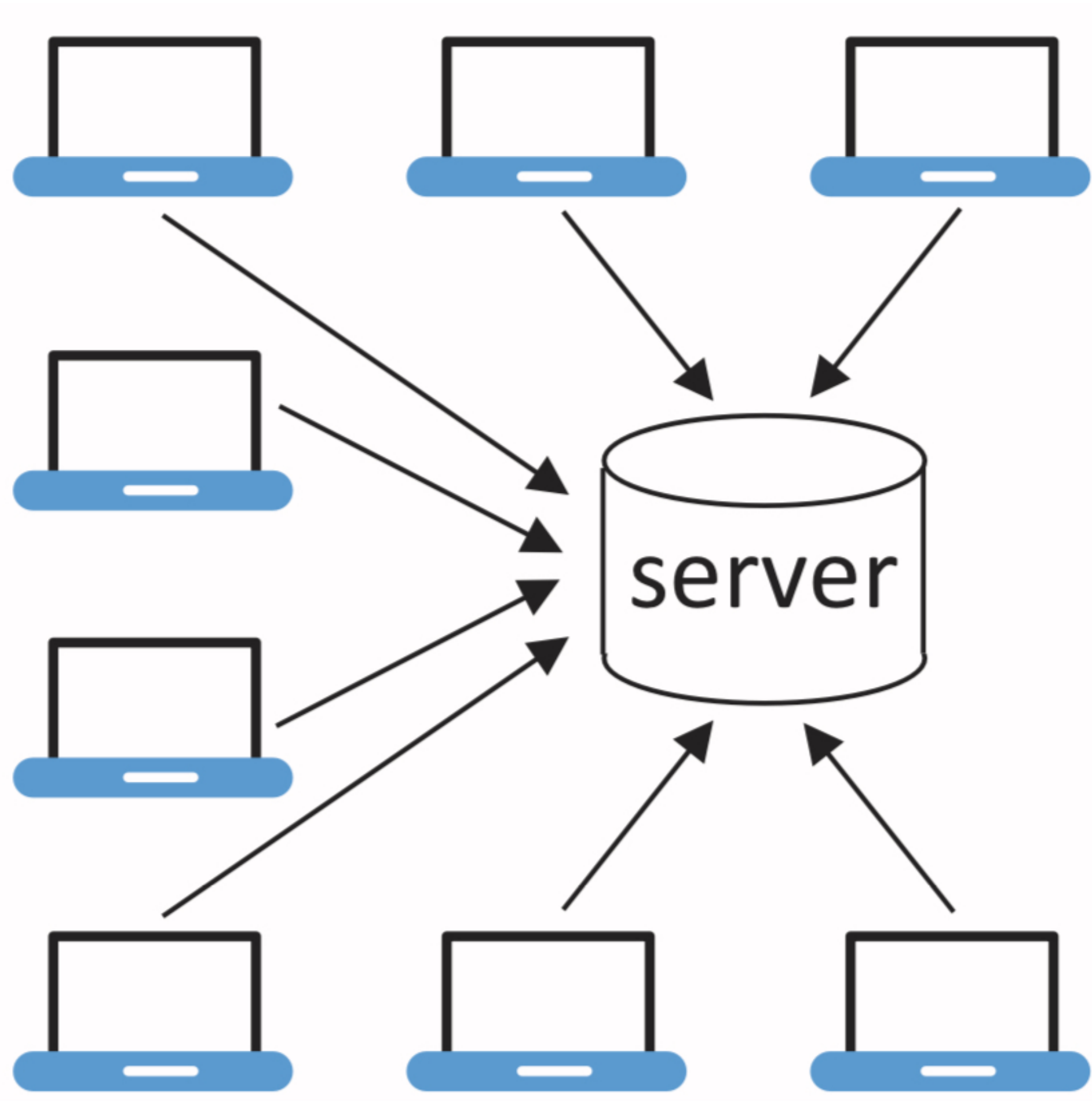
- **tcpdump** and **Wireshark** are popular tools for packet capture and processing.
- Rely on packet capture libraries (e.g., `libpcap`).
- Provide user-specified filtering of packets (e.g., ports, protocols).

Denial of Service Attacks

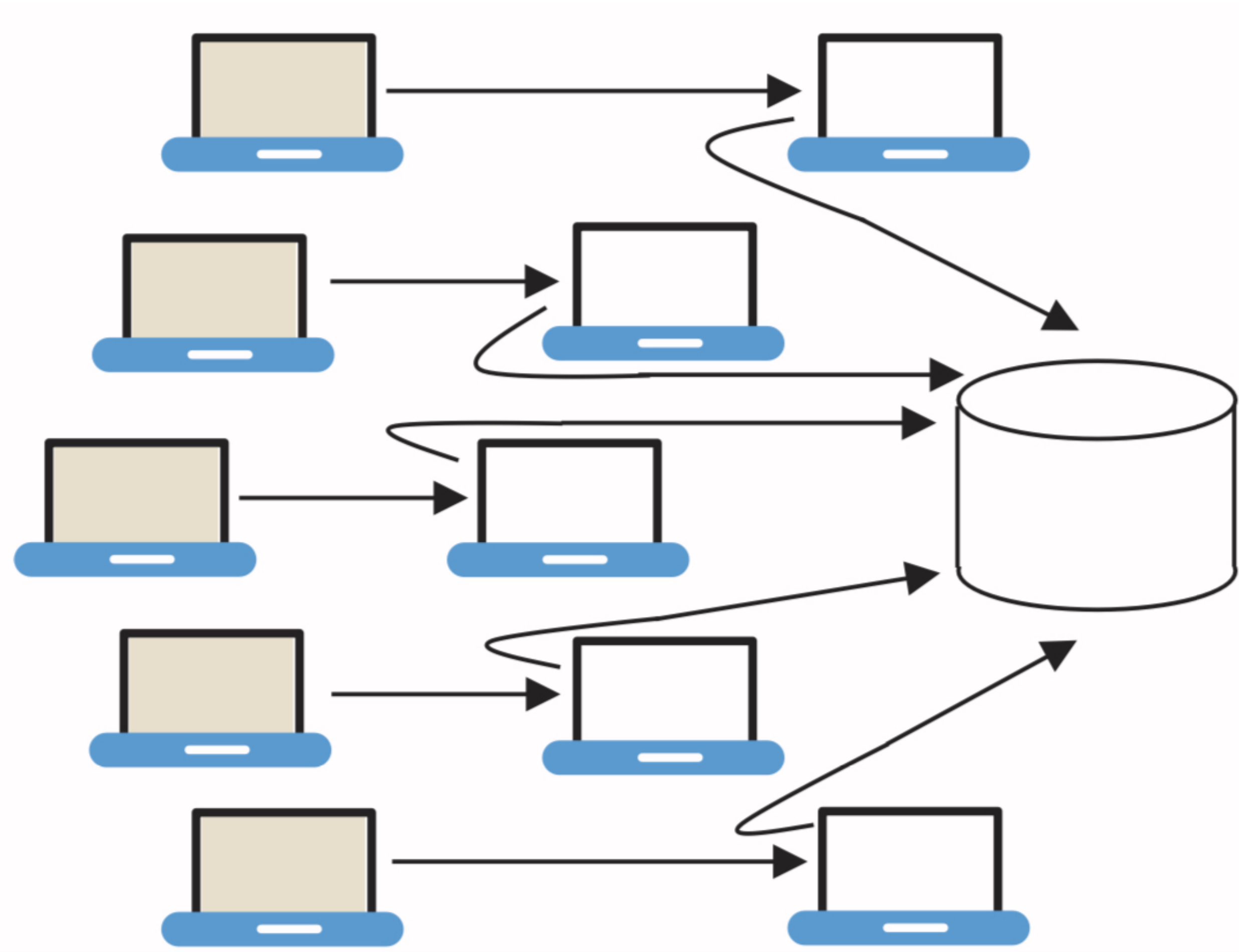
- DoS attacks **deny** legitimate **users access** to resources and services.
- **Two broad categories**, those that **exploit implementation flaws** and those that **exhaust resources**.
- DoS attacks are motivated by many factors, from *financial gain* to *activism* to *experimentation*.

Distributed Denial of Service (DDoS)

- DDoS attacks use a large number of devices across a wide array of IP addresses to flood a target.
 - Often uses a **botnet**.
 - May use **spoofed** IP addresses.
- These can result in a flood of **response packets** to the spoofed address, impacting those not involved with the initial request.



a) b)



Remote and Local DoS

- **Local DoS** can result from **malware** consuming resources or triggering **kernel flaws**.
- **Remote DoS** attacks use **network protocols** to trigger **exploits**.
- Example: **“Ping of Death”** uses **oversized** packets to **crash TCP/IP** implementations.
- Example: LAND sends a SYN packet with source and destination being the same value.

SYN Flooding

- Exploits the TCP handshake, exhausting server resources.
- An attacker sends SYN packets, but **does not complete the handshake.**
- Can be amplified using *unresponsive* and or *spoofed* addresses.

Wireless Networks and Security

Background: 802.11 WLAN Architecture

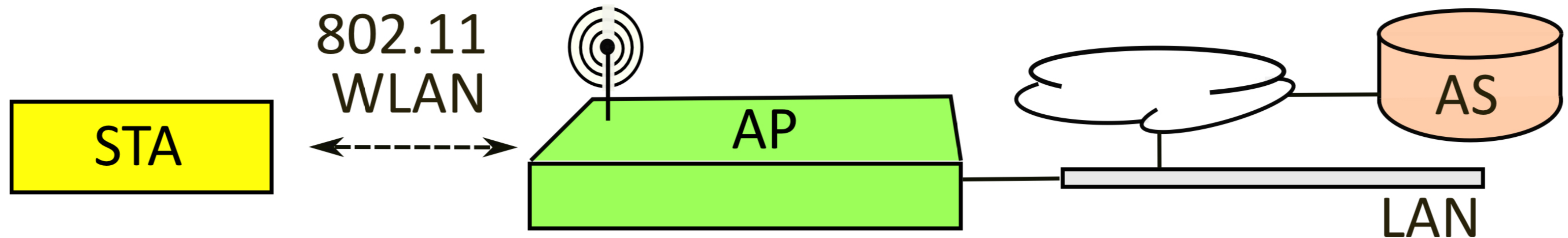
- **Ethernet** is a dominant technology for **wired LANs**, standardized as **IEEE 802.3**.
- **Wi-Fi** and **IEEE 802.11** are analogous technologies/standards for WLANs.
- Both provide an interface *insulating higher layers* from the details of the **data link** and **physical layers**.

Frame Types in 802.11

- **Data frames:** Carry upper-layer data and authentication messages.
- **Management frames:** Related to beacons, probes, associations, etc.
- **Control frames:** Facilitate access to the wireless medium.

WLAN Components

- **Stations (STAs):** Mobile devices connecting to an access point (AP) via radio frequencies (RF).
- **Access Point (AP):** Connects to a wired network, providing internet access.
- **Authentication Server (AS):** Handles authentication decisions.
- **Distribution System (DS):** Facilitates communication between STAs and the wired network via the AP.



Service Set Identifier (SSID)

- A WLAN name (up to 32 characters).
- Not a secret and is visible as plaintext in management frames.
- Different from a BSSID (AP's MAC address) or ESSID (ID for an ESS).

Infrastructure and Ad Hoc Modes

- In **infrastructure mode**, devices connect to an AP, which is connected to the wired network.
- **STAs + AP** = basic service set (BSS); multiple BSSs make an extended service set (ESS).
- In **ad hoc mode**, STAs connect **directly to each other without an AP**, called an independent basic service set (**IBSS**).

Multicast and Broadcast Addresses

- A unicast address specifies a single recipient, a multicast address specifies a group, and broadcast a LAN.
- In infrastructure mode, APs send multicast messages; STAs communicate it with the AP for sending the message.
- Broadcast messages use a group key shared by all devices.

Association, Beacons, and Probes

- For a device (STA) to connect to an AP, it goes through the process of:
 1. Sending probe messages for information. APs advertise themselves with periodic beacon frames.
 2. Selecting an AP and starting a low-level authentication process using a shared key or open system authentication.
 3. Starting the association request sequence.
 4. For data frames to be accepted, upper-layer 802.1X must have been successfully carried out.

AP Security Policy

- AP's security policy is specified by elements in beacons and probes.
- Includes authentication and encryption options, and details about the external authentication server.
- The STAs choose a suitable security suite for the connection.

WLAN Threats and Mitigations

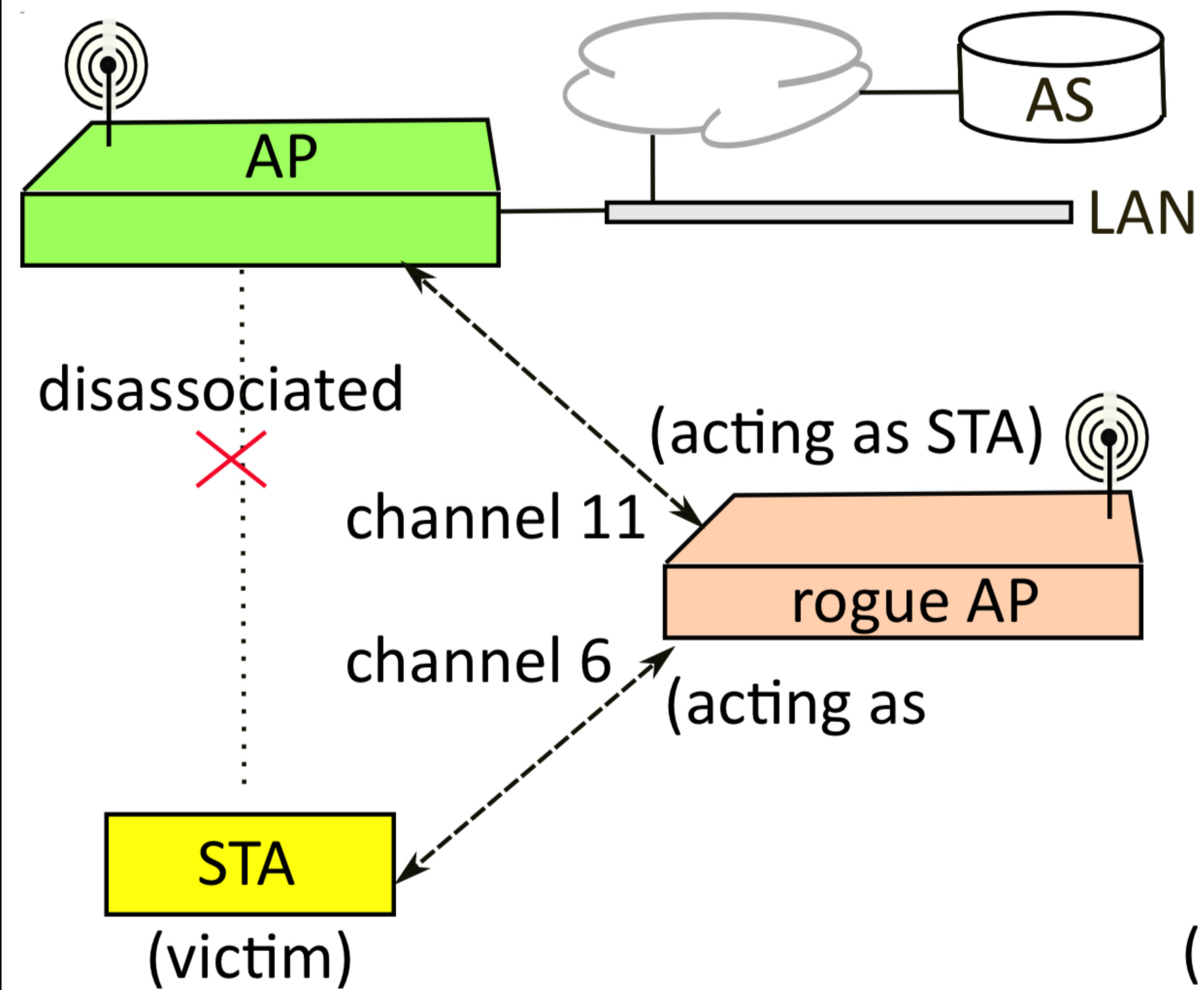
- Wireless networks have unique vulnerabilities.
- Our interest is in common and recurring error patterns, using examples of exploited vulnerabilities.
- The goal is not to analyze specific systems but to understand the fundamental security flaws in wireless systems.

Wireless Security: Link vs. End-to-End

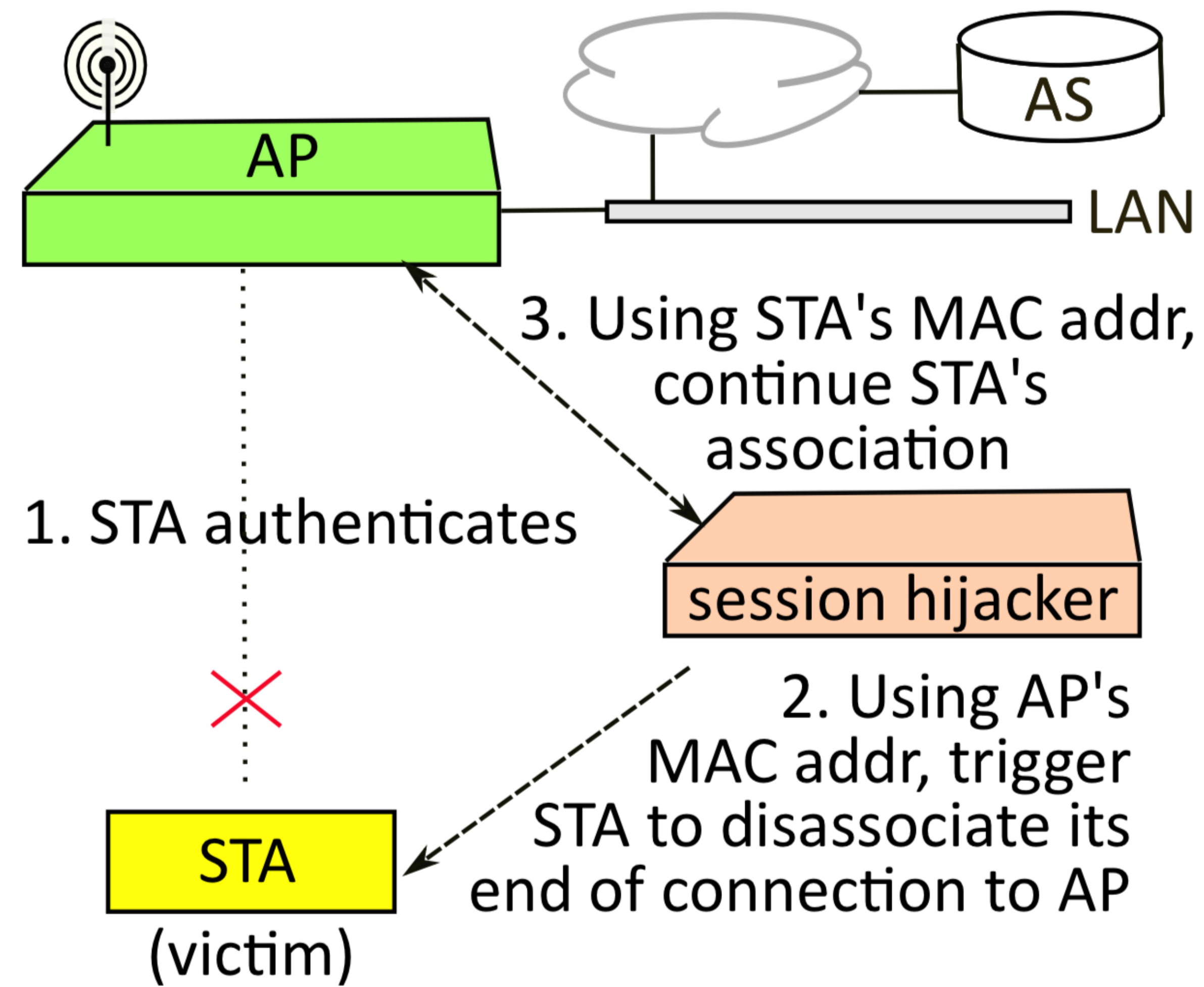
- Wireless links are not as secure as wired networks.
- A WLAN link is between the STA and the AP, not end-to-end.
- Data is decrypted at the AP, and any protection associated with the wireless link is removed once received there.

Rogue AP Attacks

- Exploit the lack of mutual authentication between STA and AP.
- The attacker sets up a rogue AP to act as a man-in-the-middle between a STA and the real AP.
- Relays messages and credentials with the real AP.



(a)



(b)

Session Hijacking

- Attackers send a disassociate frame to a STA using the AP's MAC address.
- The STA de-associates, and the attacker, while asserting its MAC address, continues the session with the AP.
- This is possible without encryption.

War Driving

- Scanning radio channels for in-range wireless networks.
- May be used for reconnaissance, or for finding open networks.
- Active war driving triggers AP responses using probes.
- NetStumbler is an example of such a tool for wireless enumeration.

Loss of Physical Basis for Threat Models

- With wireless there is no physical restriction to access and trust is more difficult to assume.
- Rogue APs are always a concern.
- Shared keys can be used by all users in Wi-Fi hotspots, leading to greater risk.